API Security Risk Analysis

1. API Overview

API Name: JSONPlaceholder
Base URL: https://jsonplaceholder.typicode.com
Endpoints Tested:

- `/users`
- `/users/{id}`

Type: Public Demo API

2.Tools Used

- Postman
- Browser DevTools

3. Methodology

- Performed read-only testing on public API endpoints
- Sent GET requests using Postman
- Inspected API responses and headers
- Identified security risks without exploitation

4. Identified Security Risks

🔴 Risk 1: No Authentication

- **Severity:** HIGH

Description:

The API allows access to endpoints without any authentication mechanism such as API keys or tokens.

Evidence:

Accessing `/users` returns full user data without login.

Impact:

- Unauthorized users can access sensitive data
- Increased risk of data scraping and misuse

Remediation:

- Implement authentication (API keys / JWT tokens)
- Restrict access to authorized users only

🔴 Risk 2: Broken Object Level Authorization (BOLA)

- **Severity:** HIGH

Description:

Users can access data of other users by modifying the ID in the endpoint.

Evidence:

- `/users/1` → works
- `/users/2` → works

Impact:

- Exposure of other users' personal data
- Privacy violations

Remediation:

- Enforce access control checks
- Ensure users can only access their own data

🟠 Risk 3: Excessive Data Exposure

- **Severity:** MEDIUM

Description:

The API returns more information than necessary, including email, phone, and address details.

Evidence:

Response includes:

- Email
- Phone number
- Full address
- Geo location

Impact:

- Sensitive information leakage
- Increased attack surface

Remediation:

- Return only required fields
- Apply data filtering

🟠 Risk 4: No Rate Limiting

- **Severity:** MEDIUM

Description:

The API does not restrict the number of requests from a single user.

Evidence:

Multiple rapid requests were allowed without restriction.

Impact:

- API abuse
- Potential denial-of-service (DoS) attacks

Remediation:

- Implement rate limiting (e.g., 100 requests/minute)
- Use throttling mechanisms

🟢 Risk 5: Missing Security Headers

- **Severity:** LOW

Description:

The API response lacks important security headers.

Evidence:

Headers do not include:

- Content Security Policy (CSP)
- X-Frame-Options
- Strict-Transport-Security

Impact:

- Increased vulnerability to client-side attacks

Remediation:

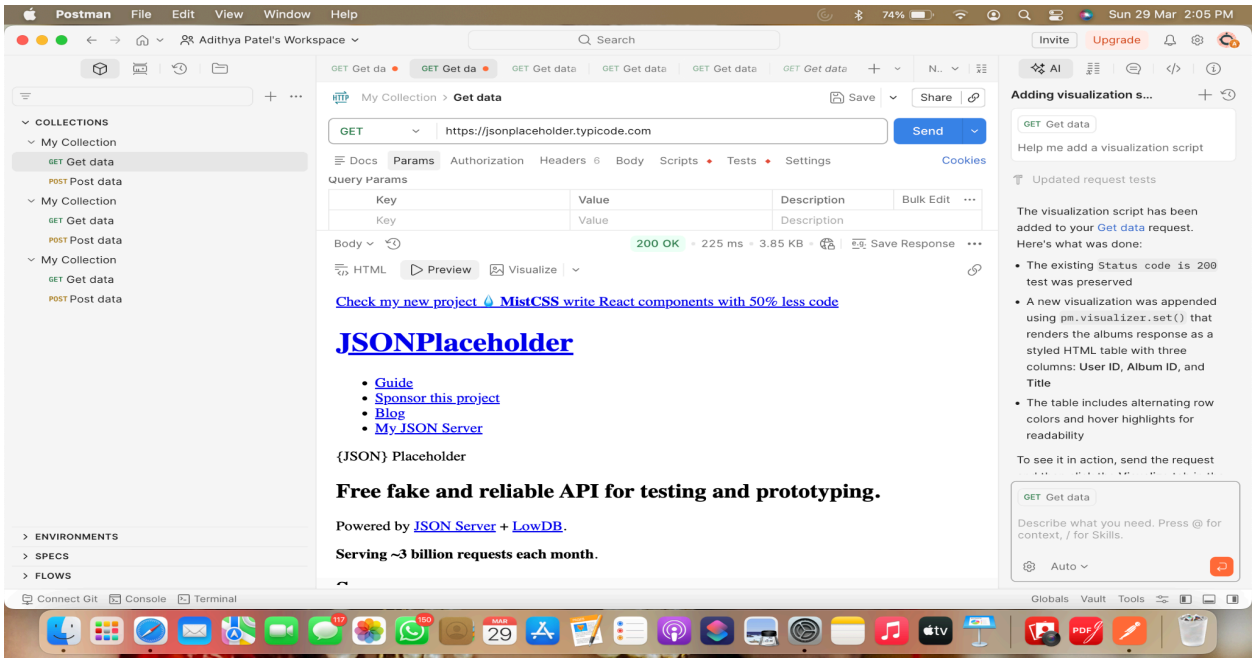
- Add standard security headers

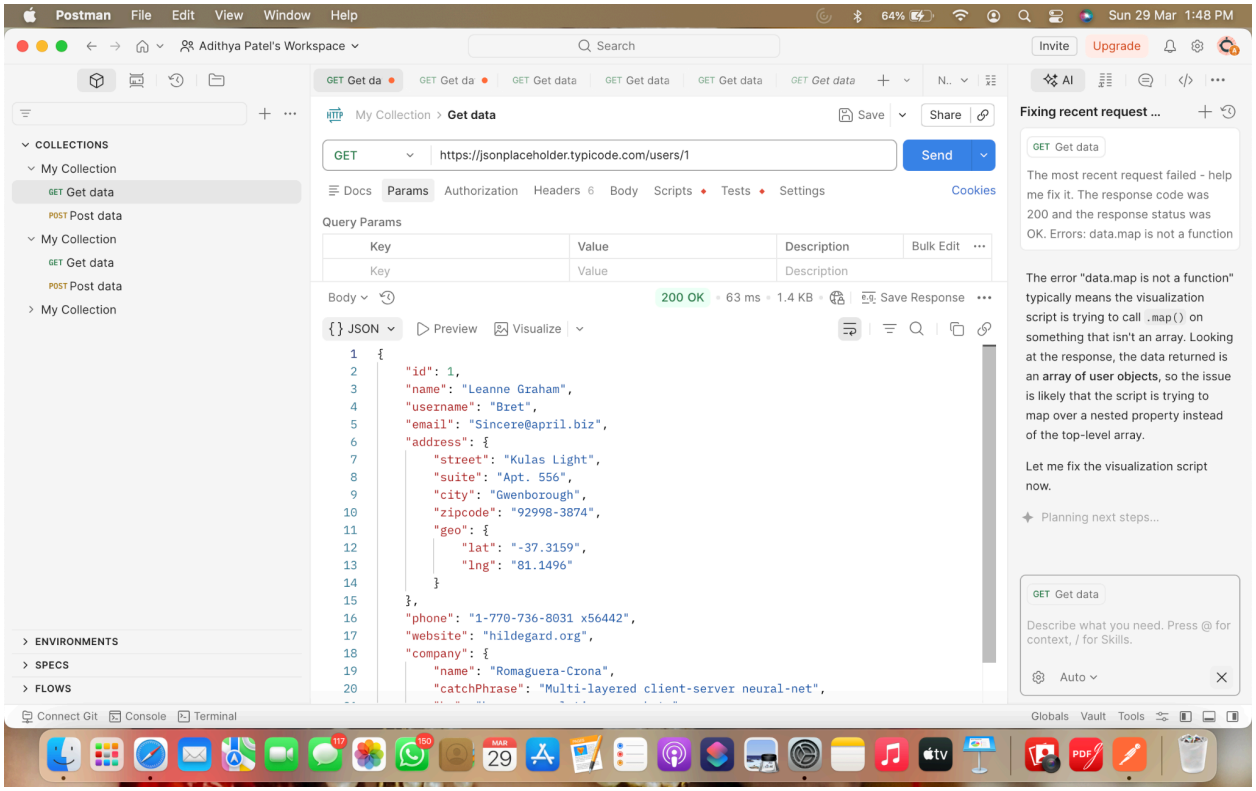
📊 5. Risk Summary

Risk	Severity
No Authentication	HIGH
Broken Authorization	HIGH
Excessive Data Exposure	MEDIUM
No Rate Limiting	MEDIUM
Missing Headers	LOW

📌 6. Conclusion

The API lacks fundamental security controls such as authentication and authorization, making it vulnerable to unauthorized access and data exposure. Implementing proper security mechanisms is essential to protect user data and prevent abuse.





Postman File Edit View Window Help 74% Sun 29 Mar 1:59 PM

Adithya Patel's Workspace | Search | Invite | Upgrade

GET Get data | GET Get data | GET Get data | GET Get data | GET Get data | GET Get data

My Collection > Get data | Save | Share

GET https://jsonplaceholder.typicode.com/posts | Send

Docs | Params | Authorization | Headers 6 | Body | Scripts | Tests | Settings | Cookies

Query Params

Key	Value	Description	Bulk Edit
Key	Value	Description	

Body | Cookies | Headers 24 | Test Results 1/1 | 200 OK • 252 ms • 7.98 KB | Save Response

JSON | Preview | Visualize

	userId	id	title	body
0	1	1	sunt aut facere repellat provident occaecati excepturi optio reprehenderit	quia et suscipit suscipit recusandae consequuntur expedita et cum reprehenderit molestiae ut ut quas totam nostrum rerum est autem sunt rem eveniet architecto
1	1	2	qui est esse	est rerum tempore vitae sequi sint nihil reprehenderit dolor beatae ea dolores neque fugiat blanditiis voluptate porro vel nihil molestiae ut reiciendis qui aperiam non debitis possimus qui neque nisi nulla
2	1	3	ea molestias quasi exercitationem repellat qui ipsa sit aut	et iusto sed quo iure voluptatem occaecati omnis eligendi aut ad voluptatem doloribus vel accusantium quis pariatur molestiae porro eius odio et labore et velit aut
3	1	4	eum et est occaecati	ullam et saepe reiciendis voluptatem adipisci sit amet autem assumenda provident rerum culpa quis hic commodi nesciunt rem tenetur doloremque ipsam iure quis sunt voluptatem rerum illo velit
4	1	5	nesciunt quas odio	repudiandae veniam quaerat sunt sed alias aut fugiat sit autem sed est voluptatem omnis possimus esse voluptatibus quis est aut tenetur dolor neque
5	1	6	dolorem eum magni eos aperiam quia	ut aspernatur corporis harum nihil quis provident sequi mollitia nobis aliquid molestiae perspiciatis et ea nemo ab reprehenderit accusantium quas voluptate dolores velit et doloremque molestiae
6	1	7	magnam facilis autem	dolore placeat quibusdam ea quo vitae magni quis enim qui quis quo nemo aut saepe quidem repellat excepturi ut quia sunt ut sequi eos ea sed quas

COLLECTIONS
- My Collection
  - GET Get data
  - POST Post data
- My Collection
  - GET Get data
  - POST Post data
- My Collection
  - GET Get data
  - POST Post data

ENVIRONMENTS
SPECS
FLOWS

Connect Git | Console | Terminal | Globals | Vault | Tools

Postman File Edit View Window Help 76% Sun 29 Mar 2:01 PM

Adithya Patel's Workspace | Search | Invite | Upgrade

GET Get da | GET Get da | GET Get data | GET Get data | GET Get data | GET Get data

My Collection > Get data | Save | Share

GET https://jsonplaceholder.typicode.com/albums | Send

Docs | Params | Authorization | Headers 6 | Body | Scripts | Tests | Settings | Cookies

Query Params

Key	Value	Description	Bulk Edit
Key	Value	Description	

Body | 200 OK • 65 ms • 3.13 KB | Save Response

JSON | Preview | Visualize

	userId	id	title
0	1	1	quidem molestiae enim
1	1	2	sunt qui excepturi placeat culpa
2	1	3	omnis laborum odio
3	1	4	non esse culpa molestiae omnis sed optio
4	1	5	eaque aut omnis a
5	1	6	natus impedit quibusdam illo est
6	1	7	quibusdam autem aliquid et et quia
7	1	8	qui fuga est a eum
8	1	9	saepe unde necessitatibus rem
9	1	10	distinctio laborum qui
10	2	11	quam nostrum impedit mollitia quod et dolor
11	2	12	consequatur autem doloribus natus consectetur

AI

Adding visualization s...

GET Get data

Help me add a visualization script

Updated request tests

The visualization script has been added to your Get data request. Here's what was done:

- The existing `Status code is 200` test was preserved
- A new visualization was appended using `pm.visualizer.set()` that renders the albums response as a styled HTML table with three columns: **User ID**, **Album ID**, and **Title**
- The table includes alternating row colors and hover highlights for readability

To see it in action, send the request

GET Get data

Describe what you need. Press @ for context, / for Skills.

Auto

COLLECTIONS
- My Collection
  - GET Get data
  - POST Post data
- My Collection
  - GET Get data
  - POST Post data
- My Collection
  - GET Get data
  - POST Post data

ENVIRONMENTS
SPECS
FLOWS

Connect Git | Console | Terminal | Globals | Vault | Tools